

PHASE 7

Security Limitations Conclusion and References

Chapters 11–13 and References: security, ethics, limitations, future work and sources

FITBUDDY • AI FITNESS PLAN GENERATOR • PROJECT REPORT

Chapter 11: Security, Privacy and Ethical Considerations

11.1 API Key Protection

The Google API key is stored in an environment variable, normally supplied through a `.env` file that is loaded at start-up. The `.env` file must be excluded from version control by listing it in `.gitignore`, and a `.env.example` file with empty values documents the required variables. Keys must never be committed to GitHub, printed in logs, shown in templates or included in this report. If a key is exposed, it should be revoked and replaced immediately.

11.2 Backend AI Calls

All Gemini calls are made from the server. If they were made from browser JavaScript, the key would be visible to every visitor and could be copied and misused. Server-side calls also allow input validation, output checking and rate control to be applied consistently, and mean that prompts and model settings cannot be altered by users.

11.3 Input Validation

Pydantic models check the type and range of every field before processing. This protects the database from malformed values, reduces the chance of unusual input reaching the prompt, and keeps error handling predictable. Free-text fields such as feedback are additionally escaped when displayed. Because free text is included in a prompt, users could attempt to influence the model with instructions of their own; prompts should therefore state that the feedback is data to be applied to the plan, and outputs should still be validated.

11.4 Admin Protection

The dashboard exposes personal fitness data and must not be publicly accessible. Access should be restricted using an authentication mechanism appropriate to the deployment. [Insert the mechanism actually used] A shared secret in an environment variable is a minimal option; session-based login with hashed passwords is stronger. Administrative routes should also be served over HTTPS in any deployment beyond local demonstration. Full role-based access control is listed as a future enhancement in Chapter 12.

11.5 User Data

FitBuddy stores name, user ID, age, weight and fitness goals, together with generated plans and feedback. Body measurements and age are personal data, and even a project system should treat them responsibly.

- Collect only the fields needed for plan generation.
- Do not use real personal data in screenshots or demonstrations; use test users.

- Restrict database file access and back it up securely.
- Tell users what is stored and why, and provide a way to delete records if the system is deployed.
- Remember that profile data is sent to an external AI service when a plan is generated, and review the provider's data-handling terms before deployment.
- Use user IDs that do not reveal personal information.

11.6 AI Ethics

- Recommendations. Output is a suggestion generated by a statistical model, and users should be told so.
- Bias. Models learn from text that may reflect stereotypes, for example about age, weight or gender. Plans for different profiles should be reviewed for unjustified differences or unsuitable assumptions.
- Incorrect recommendations. A plan may contain unsuitable exercises or unrealistic volumes. Prompt constraints and administrator review reduce, but do not remove, this risk.
- Transparency. The interface should state that content is AI-generated and that plans may vary between requests.
- Human oversight. Storing plans and revisions lets an administrator or coach review what the AI produced and intervene where necessary.

11.7 Health Disclaimer

FitBuddy is a general wellness and educational tool. It does not diagnose conditions, prescribe treatment or replace advice from a physician, physiotherapist, registered dietitian or qualified trainer. A person with a medical condition, an injury, pregnancy or any health concern should consult a professional before beginning an exercise or nutrition programme, and should stop exercising and seek advice if they experience pain, dizziness or other unusual symptoms. A short version of this statement should appear on the home page and on every generated plan.

11.8 Risk Analysis

Table 11.1 summarises the principal risks and proposed mitigations. The ratings are qualitative judgements by the author, not measured values.

Table 11.1: Risk Analysis

Risk	Likelihood	Impact	Mitigation
API key exposure	Low	High	Environment variables; .gitignore; key rotation; server-side calls only
Gemini service unavailable	Medium	Medium	Error handling; clear user message; stored data remains viewable
Malformed or incomplete AI output	Medium	Medium	JSON validation; seven-day check; nothing stored on failure
Unsafe or unsuitable recommendation	Medium	High	Safety constraints in prompt; disclaimer; administrator review
Unauthorised dashboard access	Medium	High	Access restriction; HTTPS; future RBAC
Database corruption or loss	Low	Medium	Transactions with rollback; regular backup of the SQLite file
Prompt manipulation through free text	Low	Low	Feedback treated as data; output validation
API quota or cost exhaustion	Medium	Medium	Validate before calling; monitor usage; consider rate limiting

Chapter 12: Limitations and Future Enhancements

12.1 Current Limitations

- Dependence on the Gemini API. Plan generation and revision fail when the service or network is unavailable, and are subject to quota and latency.
- Output variability. The same input can produce different plans, and quality cannot be guaranteed.
- SQLite limits. Write concurrency is restricted, so the current storage is unsuitable for large multi-server deployments.
- Limited authentication. Depending on the implementation, user identification is by a user ID rather than a secure login, and administrative protection may be basic.
- No wearable integration. The system does not read activity or heart-rate data.
- No form verification. It cannot check whether exercises are performed correctly.
- No medical personalisation. Health history is not collected or considered.
- Internet dependency. New plans cannot be generated offline.

12.2 Future Enhancements

The enhancements below are proposals and are not part of the current implementation. Table 12.1 summarises them, and each is described briefly afterwards.

Table 12.1: Proposed Future Enhancements

No.	Enhancement	Main benefit
1	User authentication	Secure, private accounts
2	Advanced RBAC	Separate user, trainer and administrator permissions
3	Progress tracking	Measure results and adapt plans
4	Wearable integration	Use real activity data
5	Computer vision	Feedback on exercise posture
6	Advanced nutrition planning	Meal plans by dietary preference
7	Mobile application	Convenient access on Android and iOS
8	PostgreSQL migration	Better concurrency and scalability
9	Analytics dashboard	Charts of progress and usage
10	AI conversation assistant	Conversational fitness questions

1. User Authentication

Secure registration and login with hashed passwords and session or token handling would ensure that users can view only their own plans.

1. Advanced RBAC

Distinct user, trainer and administrator roles would give coaches review access to their clients while limiting full administrative functions.

1. Progress Tracking

Recording weight, workout completion, exercise progress and goals would allow revision prompts to use real outcomes as well as comments.

1. Wearable Integration

Integration with smart watches and fitness trackers could supply activity and recovery data, subject to privacy safeguards and user consent.

1. Computer Vision

Posture and form analysis from camera input could warn users about unsafe technique. This would require a separate model, careful evaluation and clear statements of accuracy.

1. Advanced Nutrition Planning

Meal planning based on dietary preferences and restrictions could extend the current brief tip. It would require stronger safeguards and, for medical dietary needs, professional involvement.

1. Mobile Application

Android and iOS clients could use the same backend API and provide reminders and offline viewing of stored plans.

1. PostgreSQL Migration

Moving to PostgreSQL, with Alembic for schema migrations, would support more concurrent users and larger data volumes.

1. Analytics Dashboard

Charts of workout completion, weight trends and usage would help users and coaches review progress over time.

1. AI Conversation Assistant

A conversational interface would let users ask fitness questions in ordinary language, with the same safety constraints and disclaimers as plan generation.

Chapter 13: Conclusion

This project addressed the difficulty of obtaining personalised, revisable weekly workout guidance without professional coaching or manual planning. Generic plans and static websites do not reflect an individual's age, weight, goal or preferred intensity, and they cannot adapt when a plan proves unsuitable.

FitBuddy proposes a web-based solution built with FastAPI, Pydantic, SQLAlchemy and SQLite. A Gemini model, accessed server-side through the google-genai SDK, generates a seven-day plan in a structured form, and a Gemini Flash model produces a short nutrition and recovery tip. Model identifiers are configurable so the system can follow changes in model availability.

The feedback loop is the central feature: a user's comments are combined with the original plan and profile to produce a revised plan, while the original is preserved unchanged. Persistent storage keeps users, plans, tips, feedback and revisions, and an administrative dashboard allows authorised staff to review them. The interactive documentation at /docs makes the API easy to explore and test.

The technical contribution lies in combining these elements in a disciplined architecture: validation before AI calls, structured output, separate storage of revisions, secrets kept on the server and explicit safety wording. The system has clear limitations. It depends on an external service, its output varies, its authentication and administrative protection are basic, and it offers general wellness guidance only, not medical advice. Its results should be verified through the testing described in Chapter 9 before conclusions about quality are drawn.

Future work on authentication, role-based access, progress tracking, richer nutrition planning and a scalable database would extend the system towards a more complete coaching support tool. In its present form, FitBuddy demonstrates that generative AI can be integrated responsibly into a conventional web application to make an adjustable first draft of a fitness plan quickly available.

References

Online sources are cited from their official documentation pages. Insert the access date for each before submission. Bibliographic details of the printed and preprint works should be checked against the originals.

- [1] S. Ramírez, "FastAPI documentation," FastAPI. [Online]. Available: <https://fastapi.tiangolo.com>. [Accessed: Insert date].
- [2] Python Software Foundation, "Python documentation," Python.org. [Online]. Available: <https://docs.python.org>. [Accessed: Insert date].
- [3] SQLAlchemy Authors, "SQLAlchemy documentation," SQLAlchemy. [Online]. Available: <https://docs.sqlalchemy.org>. [Accessed: Insert date].
- [4] SQLite Consortium, "SQLite documentation," SQLite. [Online]. Available: <https://www.sqlite.org/docs.html>. [Accessed: Insert date].
- [5] Google, "Gemini API documentation," Google AI for Developers. [Online]. Available: <https://ai.google.dev/gemini-api/docs>. [Accessed: Insert date].
- [6] Google, "Google Gen AI SDK (google-genai) for Python," Google AI for Developers. [Online]. Available: <https://ai.google.dev/gemini-api/docs/libraries>. [Accessed: Insert date].
- [7] Pydantic Services Inc., "Pydantic documentation," Pydantic. [Online]. Available: <https://docs.pydantic.dev>. [Accessed: Insert date].
- [8] A. Vaswani et al., "Attention is all you need," in Advances in Neural Information Processing Systems, vol. 30, 2017.
- [9] T. B. Brown et al., "Language models are few-shot learners," in Advances in Neural Information Processing Systems, vol. 33, 2020.
- [10] Gemini Team, Google, "Gemini: A family of highly capable multimodal models," arXiv preprint arXiv:2312.11805, 2023.
- [11] World Health Organization, WHO Guidelines on Physical Activity and Sedentary Behaviour. Geneva, Switzerland: WHO, 2020.
- [12] Encode, "Uvicorn documentation," Uvicorn. [Online]. Available: <https://www.uvicorn.org>. [Accessed: Insert date].
- [13] World Health Organization, Global Action Plan on Physical Activity 2018-2030: More Active People for a Healthier World. Geneva, Switzerland: WHO, 2018.
- [14] OpenAPI Initiative, "OpenAPI Specification," Linux Foundation. [Online]. Available: <https://spec.openapis.org/oas/latest.html>. [Accessed: Insert date].
- [15] Pallets, "Jinja documentation," Pallets Projects. [Online]. Available: <https://jinja.palletsprojects.com>. [Accessed: Insert date].